

MK FRAUD READINESS

# Comprehensive fraud-readiness review

Evidence-validated, reviewer-led and board-ready.

ORGANISATION

Kestrel Industrial Supply (Pty) Ltd

NAMED REVIEWER

Independent review lead · Independent Reviewer

REVIEW DATE

10 August 2026

**Confidential · decision support, not a legal opinion or certification**

# Engagement scope

This product takes the recorded analytical universe through evidence review, interpretation and decision preparation.

## INCLUDED

Deterministic score and maturity; material findings; risk register; control actions; evidence checklist; scenarios; contradictions; roadmap; reviewer annotations; management decisions.

## NOT INCLUDED

A re-score, legal opinion, investigation, certification programme, or conclusion beyond the evidence examined and the review scope agreed with management.

## READING RULE

The recorded assessment answer is never overwritten by reviewer narrative. Each conclusion is labelled as self-reported, evidence reviewed, validated / supported, not validated / insufficient or reviewer judgement.

# Executive conclusion

The evidence review supports selected control positions, but the overall readiness position remains the recorded deterministic assessment. 8 evidence item(s) remain unresolved; board reliance should be limited to the reviewed scope and stated evidence boundaries.

|                         |                          |                        |                          |
|-------------------------|--------------------------|------------------------|--------------------------|
| Deterministic readiness | Evidence items supported | Unresolved evidence    | Decisions required       |
| 55                      | 3                        | 8                      | 4                        |
| / 100 · Developing      | of 12                    | items requiring action | management / board items |

BOARD IMPLICATION

Approve the Financial Controller mandate for detection ownership and evidence-led oversight.

# Readiness and maturity position

OVERALL SCORE

55 / 100

COVERAGE

100%

CALCULATED MATURITY

Developing

NOT APPLICABLE RATE

3%

FINAL MATURITY

Developing

CRITICAL / MAJOR GAPS

8 / 0

EXPOSURE POSITION

Not scored

MATURITY CONSTRAINT

No cap recorded

INTERPRETATION BOUNDARY

These metrics are deterministic outputs from the locked assessment run. They are not changed by reviewer judgement; evidence review changes the assurance statement around them.

# Evidence-validation summary

Validation is scoped to the items named in the evidence request pack. Evidence-item status and finding-level reviewer conclusion remain separate.

|                                                                            |             |                |                 |                          |
|----------------------------------------------------------------------------|-------------|----------------|-----------------|--------------------------|
| Not reviewed 4                                                             | Supported 3 | Insufficient 2 | Not supported 2 | Reviewed—no conclusion 1 |
| 8 of 12 items reviewed; 8 unresolved under the locked reconciliation rule. |             |                |                 |                          |

Source: Kestrel assessment, persisted reviewer record and reconciled evidence register.

## Approved fraud risk management policy and committee terms

Fraud leadership and governance

Approved fraud risk management policy and committee terms

Evidence reviewed — supported for stated scope

Demonstrated: The reviewed artefact supports the stated scope.

Reviewer confidence: HIGH

## Supplier onboarding sample pack and due-diligence exceptions

Fraud detection capability

Supplier onboarding sample pack and due-diligence exceptions

Evidence reviewed — insufficient for conclusion

Demonstrated: Population completeness or recency could not be established.

Limitation: Population completeness or recency could not be established.

Reviewer confidence: LOW

## Detection rule catalogue, tuning log and alert ageing report

Operational fraud controls

Detection rule catalogue, tuning log and alert ageing report

Evidence reviewed — not supported

Demonstrated: The artefact does not support the recorded control position for the reviewed scope.

Limitation: The artefact does not support the recorded control position for the reviewed scope.

Reviewer confidence: MEDIUM

## Whistleblowing case register and independent reporting route

Fraud leadership and governance

Evidence not requested

## Audit committee fraud dashboard and management minutes

Fraud detection capability

Evidence not requested

## Quarterly fraud risk assessment and residual-risk log

Third-party and supply chain fraud risk

Evidence reviewed — supported for stated scope

Quarterly fraud risk assessment and residual-risk log

Demonstrated: The reviewed artefact supports the stated scope.

Reviewer confidence: HIGH

User access recertification export and removal log

Fraud incident response

User access recertification export and removal log

Evidence reviewed — insufficient for conclusion

Demonstrated: Population completeness or recency could not be established.

Limitation: Population completeness or recency could not be established.

Reviewer confidence: LOW

Incident register, investigation closure pack and lessons log

Fraud culture and awareness

Incident register, investigation closure pack and lessons log

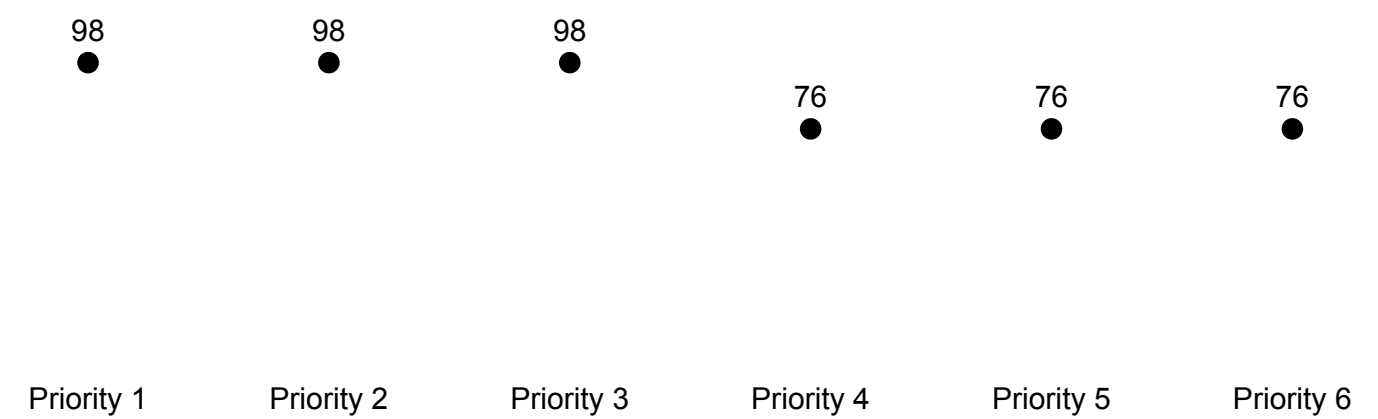
Evidence reviewed

Demonstrated: The artefact was examined; no conclusion is made beyond the stated review scope.

Reviewer confidence: MEDIUM

# What the review changes

The deterministic readiness position remains locked; the review changes the confidence boundary around named evidence and actions.



Source: Kestrel assessment, persisted reviewer record and reconciled evidence register.

# What changed after evidence review

|                                                                  |                                                                 |                   |
|------------------------------------------------------------------|-----------------------------------------------------------------|-------------------|
| AWARENESS COMPLETION IS NOT RECONCILED TO HIGHER-RISK ROLES      |                                                                 | Evidence reviewed |
| RECORDED POSITION                                                | REVIEWER INTERPRETATION                                         |                   |
| Self-reported position: Exists only informally or inconsistently | Retain the deterministic issue while keeping assurance bounded. |                   |
| TRACEABILITY                                                     |                                                                 |                   |
| Detailed references are retained in the annotated register.      |                                                                 |                   |

|                                                                       |                                                    |                                                |
|-----------------------------------------------------------------------|----------------------------------------------------|------------------------------------------------|
| COMMITTEE OVERSIGHT DOES NOT YET EVIDENCE A COMPLETE FRAUD-RISK CYCLE |                                                    | Evidence reviewed — supported for stated scope |
| RECORDED POSITION                                                     | REVIEWER INTERPRETATION                            |                                                |
| Self-reported position: No control exists                             | Retain the conclusion for the reviewed scope only. |                                                |
| TRACEABILITY                                                          |                                                    |                                                |
| Detailed references are retained in the annotated register.           |                                                    |                                                |



# Priority findings and reviewer conclusions

The report shows the highest-materiality decision items and keeps reviewer conclusions distinct from evidence persistence status. The full finding universe remains in the annotated register.

FINDING 1

Evidence reviewed — supported for stated scope

## Committee oversight does not yet evidence a complete fraud-risk cycle

DOMAIN

Fraud leadership and governance

RECORDED RESPONSE

No control exists

WHY IT MATTERS

The condition can create a credible route for loss, delayed detection or weak challenge in fraud leadership and governance.

REVIEWER OBSERVATION

The reviewer position for committee oversight does not yet evidence a complete fraud-risk cycle is bounded by the named artefact and stated scope.

REVIEWER INTERPRETATION

Retain the conclusion for the reviewed scope only.

AGREED OWNER / DUE DATE

Financial Controller · 30 days

FINDING 2

Evidence reviewed — insufficient for conclusion

## Detection tuning and alert ageing need a fixed management rhythm

DOMAIN

Fraud detection capability

RECORDED RESPONSE

No control exists

WHY IT MATTERS

The condition can create a credible route for loss, delayed detection or weak challenge in fraud detection capability.

REVIEWER OBSERVATION

The reviewer position for detection tuning and alert ageing need a fixed management rhythm is bounded by the named artefact and stated scope.

REVIEWER INTERPRETATION

Retain the deterministic issue while keeping assurance bounded.

EVIDENCE LIMITATION

The review did not establish a complete operating population or sustained effectiveness.

AGREED OWNER / DUE DATE

Financial Controller · 30 days

### FINDING 3

Evidence reviewed — not supported

## Segregation-of-duties overrides require tighter exception governance

#### DOMAIN

Operational fraud controls

#### RECORDED RESPONSE

No control exists

#### WHY IT MATTERS

The condition can create a credible route for loss, delayed detection or weak challenge in operational fraud controls.

#### REVIEWER OBSERVATION

The reviewer position for segregation-of-duties overrides require tighter exception governance is bounded by the named artefact and stated scope.

#### REVIEWER INTERPRETATION

Retain the deterministic issue while keeping assurance bounded.

#### EVIDENCE LIMITATION

The review did not establish a complete operating population or sustained effectiveness.

#### AGREED OWNER / DUE DATE

Financial Controller · 30 days

### FINDING 4

Evidence reviewed — supported for stated scope

## Supplier bank-detail changes need an independent verification step

#### DOMAIN

Third-party and supply chain fraud risk

#### RECORDED RESPONSE

Exists only informally or inconsistently

#### WHY IT MATTERS

The condition can create a credible route for loss, delayed detection or weak challenge in third-party and supply chain fraud risk.

#### REVIEWER OBSERVATION

The reviewer position for supplier bank-detail changes need an independent verification step is bounded by the named artefact and stated scope.

#### REVIEWER INTERPRETATION

Retain the conclusion for the reviewed scope only.

#### AGREED OWNER / DUE DATE

Chief Information Officer · 60 days

## FINDING 5

Evidence reviewed — insufficient for conclusion

### Incident closure records do not consistently evidence lessons applied

#### DOMAIN

Fraud incident response

#### RECORDED RESPONSE

Exists only informally or inconsistently

#### WHY IT MATTERS

The condition can create a credible route for loss, delayed detection or weak challenge in fraud incident response.

#### REVIEWER OBSERVATION

The reviewer position for incident closure records do not consistently evidence lessons applied is bounded by the named artefact and stated scope.

#### REVIEWER INTERPRETATION

Retain the deterministic issue while keeping assurance bounded.

#### EVIDENCE LIMITATION

The review did not establish a complete operating population or sustained effectiveness.

#### AGREED OWNER / DUE DATE

Chief Information Officer · 60 days

## FINDING 6

Evidence reviewed

### Awareness completion is not reconciled to higher-risk roles

#### DOMAIN

Fraud culture and awareness

#### RECORDED RESPONSE

Exists only informally or inconsistently

#### WHY IT MATTERS

The condition can create a credible route for loss, delayed detection or weak challenge in fraud culture and awareness.

#### REVIEWER OBSERVATION

The reviewer position for awareness completion is not reconciled to higher-risk roles is bounded by the named artefact and stated scope.

#### REVIEWER INTERPRETATION

Retain the deterministic issue while keeping assurance bounded.

#### EVIDENCE LIMITATION

The review did not establish a complete operating population or sustained effectiveness.

#### AGREED OWNER / DUE DATE

Chief Information Officer · 60 days

## FINDING 7

Evidence reviewed — supported for stated scope

### Privileged access exceptions are not consistently closed

#### DOMAIN

Digital and identity fraud risk

#### RECORDED RESPONSE

Operating consistently in practice

#### WHY IT MATTERS

The condition can create a credible route for loss, delayed detection or weak challenge in digital and identity fraud risk.

#### REVIEWER OBSERVATION

The reviewer position for privileged access exceptions are not consistently closed is bounded by the named artefact and stated scope.

#### REVIEWER INTERPRETATION

Retain the conclusion for the reviewed scope only.

#### AGREED OWNER / DUE DATE

Process owner · 90 days

## FINDING 8

Evidence reviewed — not supported

### Independent reporting route coverage is not demonstrated for all workers

#### DOMAIN

Whistleblowing and reporting culture

#### RECORDED RESPONSE

Operating consistently in practice

#### WHY IT MATTERS

The condition can create a credible route for loss, delayed detection or weak challenge in whistleblowing and reporting culture.

#### REVIEWER OBSERVATION

The reviewer position for independent reporting route coverage is not demonstrated for all workers is bounded by the named artefact and stated scope.

#### REVIEWER INTERPRETATION

Retain the deterministic issue while keeping assurance bounded.

#### EVIDENCE LIMITATION

The review did not establish a complete operating population or sustained effectiveness.

#### AGREED OWNER / DUE DATE

Process owner · 90 days

# Major unresolved evidence gaps

RELIANCE LIMITATION

5 item(s) remain self-reported or insufficient. These are not presented as validated weaknesses; they are assurance gaps that limit reliance. The highest-priority four are shown here; the full set remains in the annotated register.

HIGH PRIORITY

Evidence reviewed — insufficient for conclusion

Supplier onboarding sample pack and due-diligence exceptions

WHAT MK WANTS TO INSPECT

Whether the supplier onboarding sample pack and due-diligence exceptions demonstrates the stated control condition for the reviewed scope.

WHY IT MATTERS

The condition can create a credible route for loss, delayed detection or weak challenge in fraud detection capability.

ACCEPTABLE EXAMPLES

Population is complete; Approvals and exceptions are traceable; Removals are evidenced

REVIEWER NOTE

Population completeness or recency could not be established.

HIGH PRIORITY

Evidence reviewed — not supported

Detection rule catalogue, tuning log and alert ageing report

WHAT MK WANTS TO INSPECT

Whether the detection rule catalogue, tuning log and alert ageing report demonstrates the stated control condition for the reviewed scope.

WHY IT MATTERS

The condition can create a credible route for loss, delayed detection or weak challenge in operational fraud controls.

ACCEPTABLE EXAMPLES

Population is complete; Approvals and exceptions are traceable; Removals are evidenced

REVIEWER NOTE

The artefact does not support the recorded control position for the reviewed scope.

HIGH PRIORITY

Evidence not requested

## Whistleblowing case register and independent reporting route

### WHAT MK WANTS TO INSPECT

Whether the whistleblowing case register and independent reporting route demonstrates the stated control condition for the reviewed scope.

### WHY IT MATTERS

The condition can create a credible route for loss, delayed detection or weak challenge in fraud leadership and governance.

### ACCEPTABLE EXAMPLES

Population is complete; Approvals and exceptions are traceable; Removals are evidenced

### REVIEWER NOTE

Reviewer status recorded; see reviewer observation and limitations.

HIGH PRIORITY

Evidence not requested

## Audit committee fraud dashboard and management minutes

### WHAT MK WANTS TO INSPECT

Whether the audit committee fraud dashboard and management minutes demonstrates the stated control condition for the reviewed scope.

### WHY IT MATTERS

The condition can create a credible route for loss, delayed detection or weak challenge in fraud detection capability.

### ACCEPTABLE EXAMPLES

Population is complete; Approvals and exceptions are traceable; Removals are evidenced

### REVIEWER NOTE

Reviewer status recorded; see reviewer observation and limitations.

# Risk register interpretation

Risk rating remains deterministic. The reviewer assurance layer is shown beside it and does not recalculate priority, likelihood or impact.

| RISK PATHWAY                                                                                                                                                                                                                                                                   | DETERMINISTIC POSITION                                                         | REVIEWER INTERPRETATION                                                                                                                                                                                                | TARGET  |
|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------|
| <b>A supplier bank change may redirect a legitimate payment</b><br>Because independent verification is not demonstrated for the complete change population., there is a risk that an unauthorised event causes financial or operational harm before management can contain it. | Critical · Moderate / High<br>Self-assessment only, not independently verified | The critical pathway remains plausible for the reviewed operating context.<br>Assurance is limited to the named evidence and review scope.<br>No full-population operating validate was performed.<br>Confidence: HIGH | 60 days |
| <b>Privileged access may enable unauthorised record changes</b><br>Because dormant and emergency access exceptions remain open or insufficiently evidenced., there is a risk that an unauthorised event causes financial or operational harm before management can contain it. | Critical · Low / Moderate<br>Self-assessment only, not independently verified  | The critical pathway remains plausible for the reviewed operating context.<br>Assurance is limited to the named evidence and review scope.<br>No full-population operating validate was performed.<br>Confidence: HIGH | 90 days |
| <b>Fraud-risk decisions may remain unchallenged</b><br>Because a repeatable committee challenge and residual-risk acceptance cycle is not yet evidenced., there is a risk that an unauthorised event causes financial or operational harm before management can contain it.    | High · High / High<br>Self-assessment only, not independently verified         | The high pathway remains plausible for the reviewed operating context.<br>Assurance is limited to the named evidence and review scope.<br>No full-population operating validate was performed.<br>Confidence: MEDIUM   | 30 days |
| <b>Stale detection rules may delay an alert</b><br>Because tuning and alert ageing lack a fixed, accountable management cadence., there is a risk that an unauthorised event causes financial or operational harm before management can contain it.                            | High · High / High<br>Self-assessment only, not independently verified         | The high pathway remains plausible for the reviewed operating context.<br>Assurance is limited to the named evidence and review scope.<br>No full-population operating validate was performed.<br>Confidence: MEDIUM   | 30 days |
| <b>Incident lessons may not reduce repeat exposure</b><br>Because closure packs do not consistently link root cause to implemented control changes., there is a risk                                                                                                           | High · Moderate / High<br>Self-assessment only, not independently verified     | The high pathway remains plausible for the reviewed operating context.<br>Assurance is limited to the                                                                                                                  | 60 days |

| RISK PATHWAY                                                                                                                                                                                                                                                              | DETERMINISTIC POSITION                                                      | REVIEWER INTERPRETATION                                                                                                                                                                                             | TARGET  |
|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------|
| that an unauthorised event causes financial or operational harm before management can contain it.                                                                                                                                                                         |                                                                             | named evidence and review scope.<br>No full-population operating validate was performed.<br>Confidence: MEDIUM                                                                                                      |         |
| <b>An employee may not reach an independent reporting route</b><br>Because coverage across worker populations and route awareness is not demonstrated., there is a risk that an unauthorised event causes financial or operational harm before management can contain it. | Medium · Low / Moderate<br>Self-assessment only, not independently verified | The medium pathway remains plausible for the reviewed operating context. Assurance is limited to the named evidence and review scope.<br>No full-population operating validate was performed.<br>Confidence: MEDIUM | 90 days |



# Organisation-specific fraud scenarios

These are plausible scenarios linked to the recorded analytical universe. They are not allegations and do not evidence that an event occurred.

## PRIVILEGED-ACCESS

Plausible scenario

### Supplier bank-detail redirection

#### CONFIRMED OPERATING CONTEXT

Operational and digital access is material to the organisation.; Access review is recorded as not in place.

#### WHY CONTROLS MAY NOT CATCH IT

The complete population and exception process are not evidenced.

#### TRACEABILITY

Detailed references are retained in the annotated register.

#### ENTRY POINT / SEQUENCE

A stale or excessive account remains active. An unauthorised change is made and the audit trail is obscured or discovered late.

#### EARLY WARNING INDICATORS

Overdue access exceptions; Unusual change outside role pattern

#### DISCLAIMER

This is a plausible scenario, not an allegation, and is not evidence that an event occurred.

## PRIVILEGED-ACCESS

Plausible scenario

### Incident escalation delay

#### CONFIRMED OPERATING CONTEXT

Operational and digital access is material to the organisation.; Access review is recorded as not in place.

#### WHY CONTROLS MAY NOT CATCH IT

The complete population and exception process are not evidenced.

#### TRACEABILITY

Detailed references are retained in the annotated register.

#### ENTRY POINT / SEQUENCE

A stale or excessive account remains active. An unauthorised change is made and the audit trail is obscured or discovered late.

#### EARLY WARNING INDICATORS

Overdue access exceptions; Unusual change outside role pattern

#### DISCLAIMER

This is a plausible scenario, not an allegation, and is not evidence that an event occurred.

## Privileged access misuse

### CONFIRMED OPERATING CONTEXT

Manual intervention and exception volume are material.; Detection tuning is recorded as ad hoc.

### WHY CONTROLS MAY NOT CATCH IT

Rule inventory and review evidence are not current.

### TRACEABILITY

Detailed references are retained in the annotated register.

### ENTRY POINT / SEQUENCE

A pattern changes after the last rule review. Activity continues below or outside stale thresholds until a manual review identifies it.

### EARLY WARNING INDICATORS

Rising false negatives; Unreviewed high-risk rules

### DISCLAIMER

This is a plausible scenario, not an allegation, and is not evidence that an event occurred.

## Suppressed reporting

### CONFIRMED OPERATING CONTEXT

Manual intervention and exception volume are material.; Detection tuning is recorded as ad hoc.

### WHY CONTROLS MAY NOT CATCH IT

Rule inventory and review evidence are not current.

### TRACEABILITY

Detailed references are retained in the annotated register.

### ENTRY POINT / SEQUENCE

A pattern changes after the last rule review. Activity continues below or outside stale thresholds until a manual review identifies it.

### EARLY WARNING INDICATORS

Rising false negatives; Unreviewed high-risk rules

### DISCLAIMER

This is a plausible scenario, not an allegation, and is not evidence that an event occurred.

# Control-design assessment

Control design is connected to the recorded finding and evidence question. Reviewer critique is shown beside, and does not mutate, the deterministic design.

| CONTROL OBJECTIVE                                                                     | RECORDED STATE                                                                                                                                                                    | HUMAN DESIGN CRITIQUE                                                                                                                                                                                                                                                                                      | TARGET / OWNER                                                                                                                              |
|---------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Demonstrate that access rights are reviewed and removed when no longer needed.</b> | No control exists; self-assessed and not independently verified. Implement a complete role-based access review with named approver, exception ageing and removal evidence.        | The design direction is appropriate but needs complete population, exception handling and effectiveness evidence.<br>Operating effectiveness and exception closure remain to be demonstrated.<br>Implement a complete role-based access review with named approver, exception ageing and removal evidence. | A complete, role-based access review is performed at the required frequency with exceptions evidenced.<br>Chief Operating Officer · 30 days |
| <b>Demonstrate that access rights are reviewed and removed when no longer needed.</b> | No control exists; self-assessed and not independently verified. Implement a complete role-based access review with named approver, exception ageing and removal evidence.        | The design direction is appropriate but needs complete population, exception handling and effectiveness evidence.<br>Operating effectiveness and exception closure remain to be demonstrated.<br>Implement a complete role-based access review with named approver, exception ageing and removal evidence. | A complete, role-based access review is performed at the required frequency with exceptions evidenced.<br>Chief Operating Officer · 30 days |
| <b>Demonstrate that access rights are reviewed and removed when no longer needed.</b> | No control exists; self-assessed and not independently verified. Implement a complete role-based access review with named approver, exception ageing and removal evidence.        | The design direction is appropriate but needs complete population, exception handling and effectiveness evidence.<br>Operating effectiveness and exception closure remain to be demonstrated.<br>Implement a complete role-based access review with named approver, exception ageing and removal evidence. | A complete, role-based access review is performed at the required frequency with exceptions evidenced.<br>Chief Operating Officer · 30 days |
| <b>Demonstrate that detection rules are reviewed and tuned on a fixed cycle.</b>      | Exists only informally or inconsistently; self-assessed and not independently verified. Introduce a fixed detection review cycle with documented tuning, validation and sign-off. | The design direction is appropriate but needs complete population, exception handling and effectiveness evidence.<br>Operating effectiveness and                                                                                                                                                           | Detection rules are reviewed, tuned and signed off on a fixed cycle.<br>Chief Risk Officer · 60 days                                        |

| CONTROL OBJECTIVE                                                                                     | RECORDED STATE                                                                                                                                                                                    | HUMAN DESIGN CRITIQUE                                                                                                                                                                                                                                                                                            | TARGET / OWNER                                                                                                      |
|-------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------|
|                                                                                                       |                                                                                                                                                                                                   | exception closure remain to be demonstrated.<br>Introduce a fixed detection review cycle with documented tuning, validation and sign-off.                                                                                                                                                                        |                                                                                                                     |
| <b>Demonstrate that detection rules are reviewed and tuned on a fixed cycle.</b>                      | Exists only informally or inconsistently; self-assessed and not independently verified. Introduce a fixed detection review cycle with documented tuning, validation and sign-off.                 | The design direction is appropriate but needs complete population, exception handling and effectiveness evidence.<br>Operating effectiveness and exception closure remain to be demonstrated.<br>Introduce a fixed detection review cycle with documented tuning, validation and sign-off.                       | Detection rules are reviewed, tuned and signed off on a fixed cycle.<br>Chief Risk Officer · 60 days                |
| <b>Demonstrate that detection rules are reviewed and tuned on a fixed cycle.</b>                      | Exists only informally or inconsistently; self-assessed and not independently verified. Introduce a fixed detection review cycle with documented tuning, validation and sign-off.                 | The design direction is appropriate but needs complete population, exception handling and effectiveness evidence.<br>Operating effectiveness and exception closure remain to be demonstrated.<br>Introduce a fixed detection review cycle with documented tuning, validation and sign-off.                       | Detection rules are reviewed, tuned and signed off on a fixed cycle.<br>Chief Risk Officer · 60 days                |
| <b>Demonstrate that staff receive fraud-awareness training at induction and on a recurring cycle.</b> | Operating consistently in practice; self-assessed and not independently verified. Maintain a complete training population, role mapping, completion exceptions and periodic effectiveness review. | The design direction is appropriate but needs complete population, exception handling and effectiveness evidence.<br>Operating effectiveness and exception closure remain to be demonstrated.<br>Maintain a complete training population, role mapping, completion exceptions and periodic effectiveness review. | Induction and recurring training coverage is complete, current and role-specific.<br>Chief People Officer · 90 days |
| <b>Demonstrate that staff receive fraud-awareness training at induction and on a recurring cycle.</b> | Operating consistently in practice; self-assessed and not independently verified. Maintain a complete training population, role mapping, completion exceptions and periodic effectiveness review. | The design direction is appropriate but needs complete population, exception handling and effectiveness evidence.<br>Operating effectiveness and exception closure remain to be demonstrated.<br>Maintain a complete training population, role mapping, completion exceptions and periodic effectiveness review. | Induction and recurring training coverage is complete, current and role-specific.<br>Chief People Officer · 90 days |



# Leadership decisions

The Comprehensive product moves from diagnosis to decisions with traceable ownership. Options and trade-offs are shown only where the reviewer supplied them.

| ACCOUNTABLE EXECUTIVE MANDATE                                                                                                       |                                                                                                                                                                              | Decision required |
|-------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------|
| <b>Approve the Financial Controller mandate for detection ownership and evidence-led oversight.</b>                                 |                                                                                                                                                                              |                   |
| WHY NOW                                                                                                                             | VIAIBLE OPTIONS                                                                                                                                                              |                   |
| The policy is approved, but committee minutes do not show a repeatable challenge, action ageing and residual-risk acceptance cycle. | Option A: assign ownership internally; Option B: appoint a specialist partner for the first cycle; Option C: combine internal ownership with targeted specialist validation. |                   |
| KEY TRADE-OFFS                                                                                                                      | REVIEWER RECOMMENDATION                                                                                                                                                      |                   |
| Option B provides the fastest independent capability uplift but creates recurring cost and a handover dependency.                   | Select the option that gives Financial Controller a named first deliverable, a costed trade-off and a review checkpoint.                                                     |                   |
| MANAGEMENT / BOARD DECISION                                                                                                         | ACCOUNTABLE EXECUTIVE                                                                                                                                                        |                   |
| Management to confirm Financial Controller as accountable and record the selected option.                                           | Financial Controller                                                                                                                                                         |                   |
| TARGET DATE                                                                                                                         | IMMEDIATE DELIVERABLE                                                                                                                                                        |                   |
| 29 November 2026                                                                                                                    | Approve the detection ownership mandate and first evidence cycle.                                                                                                            |                   |
| CONSEQUENCE OF DELAY                                                                                                                | TRACEABILITY                                                                                                                                                                 |                   |
| Option B provides the fastest independent capability uplift but creates recurring cost and a handover dependency.                   | Detailed references are retained in the annotated register.                                                                                                                  |                   |

# Approve the operating model for supplier bank-detail verification.

WHY NOW

The supplier change report records approvals, but the evidence does not demonstrate independent call-back verification for the complete population.

KEY TRADE-OFFS

Centralisation improves consistency; business-owner confirmation preserves context; a service improves scale but adds vendor dependency.

MANAGEMENT / BOARD DECISION

Management to confirm Chief Financial Officer as accountable and record the selected option.

TARGET DATE

30 October 2026

CONSEQUENCE OF DELAY

Centralisation improves consistency; business-owner confirmation preserves context; a service improves scale but adds vendor dependency.

VIABLE OPTIONS

Option A: centralise verification in Accounts Payable; Option B: require business-owner confirmation; Option C: use a bank-validation service with exception review.

REVIEWER RECOMMENDATION

Select the option that gives Chief Financial Officer a named first deliverable, a costed trade-off and a review checkpoint.

ACCOUNTABLE EXECUTIVE

Chief Financial Officer

IMMEDIATE DELIVERABLE

Reconcile supplier bank-detail changes and add independent verification.

TRACEABILITY

Detailed references are retained in the annotated register.

Approve the sequence for privileged-access exception closure.

WHY NOW

The access export identifies dormant privileged accounts and emergency access, while removal and exception closure are not consistently evidenced.

KEY TRADE-OFFS

Closing dormant access reduces immediate exposure; redesign is more durable; parallel work requires stronger delivery capacity.

MANAGEMENT / BOARD DECISION

Management to confirm Chief Information Officer as accountable and record the selected option.

TARGET DATE

30 October 2026

CONSEQUENCE OF DELAY

Closing dormant access reduces immediate exposure; redesign is more durable; parallel work requires stronger delivery capacity.

VIABLE OPTIONS

Option A: close dormant access first; Option B: redesign role profiles first; Option C: run both tracks with weekly exception governance.

REVIEWER RECOMMENDATION

Select the option that gives Chief Information Officer a named first deliverable, a costed trade-off and a review checkpoint.

ACCOUNTABLE EXECUTIVE

Chief Information Officer

IMMEDIATE DELIVERABLE

Close dormant privileged access and govern emergency access.

TRACEABILITY

Detailed references are retained in the annotated register.



Approve the independent reporting and incident-learning improvement route.

WHY NOW

The detection catalogue exists, but the tuning log and ageing report do not yet demonstrate a fixed review cycle for high-risk rules.

KEY TRADE-OFFS

An independent channel increases confidence quickly; a blended route preserves internal context but needs clear privacy and escalation ownership.

MANAGEMENT / BOARD DECISION

Management to confirm Chief People Officer as accountable and record the selected option.

TARGET DATE

29 November 2026

CONSEQUENCE OF DELAY

An independent channel increases confidence quickly; a blended route preserves internal context but needs clear privacy and escalation ownership.

VIABLE OPTIONS

Option A: strengthen the internal route; Option B: commission an independent channel; Option C: use a blended route with quarterly effectiveness validation.

REVIEWER RECOMMENDATION

Select the option that gives Chief People Officer a named first deliverable, a costed trade-off and a review checkpoint.

ACCOUNTABLE EXECUTIVE

Chief People Officer

IMMEDIATE DELIVERABLE

Run the first fixed-cycle detection tuning review.

TRACEABILITY

Detailed references are retained in the annotated register.

# Agreed action priorities

| DECISION / ACTION                                                                                                                                                                                                                      | OWNER                     | TARGET DATE      | STATUS   | COMPLETION EVIDENCE                                                               |
|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------|------------------|----------|-----------------------------------------------------------------------------------|
| <b>Approve the Financial Controller mandate for detection ownership and evidence-led oversight.</b><br>Option B provides the fastest independent capability uplift but creates recurring cost and a handover dependency.               | Financial Controller      | 29 November 2026 | Accepted | Update the annotated register with the agreed evidence and effectiveness measure. |
| <b>Approve the operating model for supplier bank-detail verification.</b><br>Centralisation improves consistency; business-owner confirmation preserves context; a service improves scale but adds vendor dependency.                  | Chief Financial Officer   | 30 October 2026  | Open     | Update the annotated register with the agreed evidence and effectiveness measure. |
| <b>Approve the sequence for privileged-access exception closure.</b><br>Closing dormant access reduces immediate exposure; redesign is more durable; parallel work requires stronger delivery capacity.                                | Chief Information Officer | 30 October 2026  | Open     | Update the annotated register with the agreed evidence and effectiveness measure. |
| <b>Approve the independent reporting and incident-learning improvement route.</b><br>An independent channel increases confidence quickly; a blended route preserves internal context but needs clear privacy and escalation ownership. | Chief People Officer      | 29 November 2026 | Open     | Update the annotated register with the agreed evidence and effectiveness measure. |

# 12-month implementation view

Near-term actions preserve the dependency-closed Comprehensive projection of the analytical roadmap. The full L1 roadmap remains in the annotated register.

| PERIOD  | DELIVERABLE                                                              | OWNER                     | DEPENDENCY / EVIDENCE                                                                       |
|---------|--------------------------------------------------------------------------|---------------------------|---------------------------------------------------------------------------------------------|
| 30 days | Approve the detection ownership mandate and first evidence cycle.        | Financial Controller      | No dependency recorded · Approved access review export, exception log and removal evidence. |
| 30 days | Run the first fixed-cycle detection tuning review.                       | Chief Information Officer | No dependency recorded · Approved access review export, exception log and removal evidence. |
| 30 days | Review segregation-of-duties overrides and expiry.                       | Financial Controller      | No dependency recorded · Approved access review export, exception log and removal evidence. |
| 30 days | Reconcile supplier bank-detail changes and add independent verification. | Chief Information Officer | No dependency recorded · Approved access review export, exception log and removal evidence. |
| 60 days | Reconcile supplier bank-detail changes and add independent verification. | Chief Information Officer | No dependency recorded · Tuning log, validate results and approvals.                        |
| 60 days | Reconcile role-based awareness coverage.                                 | Chief Information Officer | No dependency recorded · Tuning log, validate results and approvals.                        |
| 60 days | Link incident closure to root cause and control improvement.             | Financial Controller      | No dependency recorded · Tuning log, validate results and approvals.                        |
| 90 days | Approve the detection ownership mandate and first evidence cycle.        | Financial Controller      | No dependency recorded · Completion report, role map and effectiveness review.              |

IMPLEMENTATION RULE

Do not close an action on narrative completion alone. Record the operating evidence, owner and effectiveness measure in the annotated register.

# Residual and uncertain matters

The following matters remain uncertain until their evidence boundary is closed or management formally accepts the residual risk.

- Supplier onboarding sample pack and due-diligence exceptions · Evidence reviewed — insufficient for conclusion · Population completeness or recency could not be established.
- Detection rule catalogue, tuning log and alert ageing report · Evidence reviewed — not supported · The artefact does not support the recorded control position for the reviewed scope.
- Whistleblowing case register and independent reporting route · Evidence not requested · Reviewer status recorded; see reviewer observation and limitations.
- Audit committee fraud dashboard and management minutes · Evidence not requested · Reviewer status recorded; see reviewer observation and limitations.
- User access recertification export and removal log · Evidence reviewed — insufficient for conclusion · Population completeness or recency could not be established.

## TRACKING RECOMMENDATION

Board oversight should track the unresolved evidence count, age of open actions, validation coverage for high-priority controls and overdue management decisions.

# Evidence and conclusion reconciliation

The evidence ledger is reconciled before management conclusions are presented. Every reviewed item has one and only one outcome.

|                                                                   |                                                                                         |                                              |                                                |
|-------------------------------------------------------------------|-----------------------------------------------------------------------------------------|----------------------------------------------|------------------------------------------------|
| Total evidence items<br><b>12</b><br>complete request<br>universe | Evidence reviewed<br><b>1</b><br>supported + insufficient +<br>not supported + reviewed | Supported<br><b>3</b><br>reviewed conclusion | Unresolved<br><b>8</b><br>open or insufficient |
|-------------------------------------------------------------------|-----------------------------------------------------------------------------------------|----------------------------------------------|------------------------------------------------|

| RECONCILIATION CHECK                                                     | RESULT                                           | MANAGEMENT READING                                           |
|--------------------------------------------------------------------------|--------------------------------------------------|--------------------------------------------------------------|
| Not reviewed + reviewed = total                                          | 4 + 1 = 12                                       | Open items remain bounded as self-reported.                  |
| Supported + insufficient + not supported + reviewer judgement = reviewed | 3 + 2 + 2 + 0 + 1 = 1                            | No outcome is silently dropped.                              |
| Unresolved formula                                                       | 8 = self-reported + insufficient + not supported | Closure requires evidence or a recorded management decision. |

RELIANCE BOUNDARY

A reviewed artefact can support only the stated population, period and control characteristic. It does not convert unrelated or unreviewed items into assurance.

# Reviewer observation ledger

These observations are the human review record behind the conclusion. The annotated register retains the full technical traceability.

| SUBJECT                                                                                                                                 | RECORDED POSITION                                                                   | EVIDENCE EXAMINED | LIMITATION / RESPONSE                               |
|-----------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------|-------------------|-----------------------------------------------------|
| <b>Evidence review: Approved fraud risk management policy and committee terms</b><br>Evidence reviewed — supported for stated scope     | The reviewed artefact supports the stated scope.                                    | evidence:         | Linked finding and action retained in the register. |
| <b>Evidence review: Quarterly fraud risk assessment and residual-risk log</b><br>Evidence reviewed — supported for stated scope         | The reviewed artefact supports the stated scope.                                    | evidence:         | Linked finding and action retained in the register. |
| <b>Evidence review: Supplier master change report and bank-detail approval trail</b><br>Evidence reviewed — supported for stated scope  | The reviewed artefact supports the stated scope.                                    | evidence:         | Linked finding and action retained in the register. |
| <b>Evidence review: Supplier onboarding sample pack and due-diligence exceptions</b><br>Evidence reviewed — insufficient for conclusion | Population completeness or recency could not be established.                        | evidence:         | Linked finding and action retained in the register. |
| <b>Evidence review: User access recertification export and removal log</b><br>Evidence reviewed — insufficient for conclusion           | Population completeness or recency could not be established.                        | evidence:         | Linked finding and action retained in the register. |
| <b>Evidence review: Privileged account register and emergency-access review</b><br>Evidence reviewed — not supported                    | The artefact does not support the recorded control position for the reviewed scope. | evidence:         | Linked finding and action retained in the register. |
| <b>Evidence review: Detection rule catalogue, tuning log and alert ageing report</b><br>Evidence reviewed — not supported               | The artefact does not support the recorded control position for the reviewed scope. | evidence:         | Linked finding and action retained in the register. |
| <b>Evidence review: Incident register, investigation closure pack and lessons log</b><br>Evidence reviewed                              | The artefact was examined; no conclusion is made beyond the stated review scope.    | evidence:         | Linked finding and action retained in the register. |

## REVIEW DISCIPLINE

The reviewer observation is not a replacement for the deterministic answer. It records what was examined, what it demonstrated and where management still needs to close the

boundary.

# Control ownership and effectiveness validation

Closure is evidenced through population completeness, approval traceability, exception ageing and a repeatable effectiveness measure.

| CONTROL PRIORITY                                                               | ACCOUNTABLE OWNER       | FIRST EVIDENCE DELIVERABLE                     | EFFECTIVENESS VALIDATION                                              |
|--------------------------------------------------------------------------------|-------------------------|------------------------------------------------|-----------------------------------------------------------------------|
| Demonstrate that access rights are reviewed and removed when no longer needed. | Chief Operating Officer | Current access review export and exception log | 100% of in-scope access reviewed with overdue exceptions escalated.   |
| Demonstrate that access rights are reviewed and removed when no longer needed. | Chief Operating Officer | Current access review export and exception log | 100% of in-scope access reviewed with overdue exceptions escalated.   |
| Demonstrate that access rights are reviewed and removed when no longer needed. | Chief Operating Officer | Current access review export and exception log | 100% of in-scope access reviewed with overdue exceptions escalated.   |
| Demonstrate that detection rules are reviewed and tuned on a fixed cycle.      | Chief Risk Officer      | Detection tuning log and rule-change approvals | All active rules reviewed monthly with stale-rule exceptions tracked. |
| Demonstrate that detection rules are reviewed and tuned on a fixed cycle.      | Chief Risk Officer      | Detection tuning log and rule-change approvals | All active rules reviewed monthly with stale-rule exceptions tracked. |
| Demonstrate that detection rules are reviewed and tuned on a fixed cycle.      | Chief Risk Officer      | Detection tuning log and rule-change approvals | All active rules reviewed monthly with stale-rule exceptions tracked. |

CLOSURE RULE

Close only when the register shows the population, exceptions, approvals, operating sample and next effectiveness review.



# Decision options and trade-offs

Each decision is presented with distinct options so management can record cost, speed, ownership and control consequences explicitly.

| Option                                                                                              | Decision                                                                                                                                                                        | Accountable owner         | Timing  | Trade-off                                                                                                                                         |
|-----------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------|---------|---------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Approve the Financial Controller mandate for detection ownership and evidence-led oversight.</b> | Option A: assign ownership internally;<br>Option B: appoint a specialist partner for the first cycle; Option C: combine internal ownership with targeted specialist validation. | Financial Controller      | 30 days | Option B provides the fastest independent capability uplift but creates recurring cost and a handover dependency.                                 |
| <b>Approve the operating model for supplier bank-detail verification.</b>                           | Option A: centralise verification in Accounts Payable; Option B: require business-owner confirmation; Option C: use a bank-validation service with exception review.            | Chief Financial Officer   | 60 days | Centralisation improves consistency; business-owner confirmation preserves context; a service improves scale but adds vendor dependency.          |
| <b>Approve the sequence for privileged-access exception closure.</b>                                | Option A: close dormant access first;<br>Option B: redesign role profiles first; Option C: run both tracks with weekly exception governance.                                    | Chief Information Officer | 90 days | Closing dormant access reduces immediate exposure; redesign is more durable; parallel work requires stronger delivery capacity.                   |
| <b>Approve the independent reporting and incident-learning improvement route.</b>                   | Option A: strengthen the internal route;<br>Option B: commission an independent channel; Option C: use a blended route with quarterly effectiveness testing.                    | Chief People Officer      | 30 days | An independent channel increases confidence quickly; a blended route preserves internal context but needs clear privacy and escalation ownership. |

Source: Kestrel assessment, persisted reviewer record and reconciled evidence register.

# Management assurance cadence

The review becomes useful when owners convert the evidence boundary into a repeatable management rhythm.

MONTHLY

Review high-risk detection rules, alert ageing, supplier bank-detail exceptions and privileged-access exceptions.

QUARTERLY

Reconcile the fraud-risk population, committee challenge, whistleblowing route coverage and awareness exceptions.

BOARD CHECKPOINT

Review supported conclusions, unresolved count, action ageing, accepted residual risk and decision status.

ESCALATION

Escalate overdue critical exceptions, incomplete populations and any control claim that cannot be reproduced from the named evidence.

MANAGEMENT VALIDATION

Can the accountable owner reproduce the evidence, explain the exception threshold and show that the control operated again after remediation?

# Methodology and limitations

## ANALYTICAL BASIS

Existing locked deterministic score, maturity, evidence-model material findings, risk register, control-action register, evidence checklist, scenarios, contradictions and roadmap.

## REVIEWER BASIS

Named reviewer observations, evidence examined, validation status, limitations, adjusted interpretation and management responses supplied for this engagement.

## LIMITATIONS

No inference beyond reviewed evidence; no legal or forensic conclusion; no hidden validation; no silent mutation of answers.

## TRACEABILITY

Detailed evidence, finding and methodology references are retained in the annotated register.

## STATUS VOCABULARY

Self-reported is not validated. Evidence reviewed means the artefact was examined, not that the control was supported. Validated / supported is used only where the named reviewer recorded that status for the stated scope.

# Named reviewer and sign-off

REVIEWER

Independent review lead

ROLE

Independent Reviewer

ORGANISATION

MK Fraud Readiness

REVIEW DATE

10 August 2026

SIGN-OFF STATUS

Signed

SIGNED AT

10 August 2026

REVIEWER NOTE

Reviewed for owner discussion and evidence-linked management action.

BOARD DECISIONS CAPTURED

Management to confirm the selected option, owner and evidence checkpoint for Financial Controller.; Management to confirm the selected option, owner and evidence checkpoint for Chief Financial Officer.; Management to confirm the selected option, owner and evidence checkpoint for Chief Information Officer.; Management to confirm the selected option, owner and evidence checkpoint for Chief People Officer.

SCOPE ACKNOWLEDGEMENT

This report is a decision-support deliverable. It is bounded by the information supplied, the evidence examined and the limitations recorded by the named reviewer.